

Report 15/05/26

Alunno: Pancrazio Giuzio

Traccia: Rispondere ai seguenti quesiti, con riferimento al file eseguibile notepad-classico.exe contenuto in questo file compresso:

<https://drive.google.com/file/d/1HNnJDSY7FbD1KHfiRzA2wVNHhZTJndUD/view?usp=sharing>

- Indicare le librerie importate dal malware, fornendo una descrizione per ognuna di esse tramite AI;
- Indicare le sezioni di cui si compone il malware, fornendo una descrizione per ognuna di essa tramite AI.

Suggerimento: ChatGPT (o altri LLM) possono ricevere in input degli screenshot da analizzare e cerca librerie caricate dinamicamente nei testi del codice

Svolgimento:

Dopo aver scaricato il file notepad-classico andiamo ad isolare la nostra Flare VM per analizzare in maniera statica il file , come prima cosa estraiamo tramite CFF explorer il file md5 dell'applicazione.

CFF Explorer VIII - [notepad-classico.exe]

File Settings ?

notepad-classico.exe

- notepad-classico.exe
 - comdlg32.dll
 - SHELL32.dll
 - WINSPOOL.DRV
 - COMCTL32.dll
 - msvcrt.dll
 - ADVAPI32.dll
 - KERNEL32.dll
 - GDI32.dll
 - USER32.dll

Property	Value
File Name	C:\Users\FlareVm\Desktop\Malware\notepad-classico.exe
File Type	Portable Executable 32
File Info	No match found.
File Size	282.50 KB (289280 bytes)
PE Size	282.50 KB (289280 bytes)
Created	Friday 15 May 2026, 03.33.43
Modified	Friday 15 May 2026, 03.33.43
Accessed	Friday 15 May 2026, 03.40.04
MD5	8A00A5C59AC157754CA575D721BCF960
SHA-1	C31E260630D6553E2000F8E5F8DC270C751780D9

Property	Value
CompanyName	Microsoft Corporation
FileDescription	Blocco note
FileVersion	5.1.2600.5512 (xpsp.080413-2105)
InternalName	Notepad
LegalCopyright	© Microsoft Corporation. Tutti i diritti riservati.
OriginalFilename	NOTEPAD.EXE
ProductName	Sistema operativo Microsoft® Windows®

Le librerie che il malware chiama a se per l'esecuzione del programma sono tutte librerie legittime per l'avvio di notepad-classico , tuttavia ,sappiamo che il loro funzionamento puo' variare. con una breve ricerca su Gemini possiamo vedere cosa fanno queste librerie:
comdlg32.dll

- Gestisce le finestre di dialogo standard del sistema operativo.
- Consente all'app di mostrare le schermate "Apri file", "Salva con nome" e "Stampa".

SHELL32.dll

- Fornisce le funzionalità dell'interfaccia utente di Windows Shell.
- Gestisce l'apertura dei file, le icone del desktop e i collegamenti multimediali.

WINSPOOL.DRV

- Funge da interfaccia per il sottosistema di stampa di Windows.
- Invia i documenti alla coda di stampa e comunica con i driver della stampante.

COMCTL32.dll

- Contiene i controlli grafici comuni di Windows.
- Mostra elementi visivi avanzati come barre degli strumenti, schede (tab) e barre di stato.

msvcrt.dll

- È la libreria di runtime standard del linguaggio C per Windows.
- Fornisce funzioni base come la gestione della memoria, stringhe e operazioni di input/output.

ADVAPI32.dll

- Fornisce chiamate API di sicurezza e amministrazione avanzata.
- Gestisce l'accesso al Registro di sistema di Windows e il controllo degli account utente.

KERNEL32.dll

- È il nucleo fondamentale del sistema operativo accessibile alle applicazioni.
- Gestisce i processi, i thread, la memoria RAM e l'accesso diretto ai file su disco.

GDI32.dll

- Grafica bidimensionale (Graphics Device Interface).
- Disegna i font del testo, le linee, i rettangoli e gestisce i colori sullo schermo.

USER32.dll

- Gestisce l'interfaccia utente standard e le finestre base.
- Riceve gli input da mouse e tastiera e muove o ridimensiona la finestra del Blocco Note.

AliCloud	⚠ Trojan:Win/Meterpreter.AA(dyn)	ALYac	⚠ Win32.Rozena.B
Antiy-AVL	⚠ Trojan/Win32.Meterpreter.a	Arcabit	⚠ Win32.Rozena.B
Arctic Wolf	⚠ Unsafe	Avast	⚠ Win32:MsfShell-H [Trj]
AVG	⚠ Win32:MsfShell-H [Trj]	Avira (no cloud)	⚠ TR/Patched.Gen
BitDefender	⚠ Win32.Rozena.B	Bkav Pro	⚠ W32.AIDetectMalware
ClamAV	⚠ Win.Exploit.Meterpreter-9777172-0	CrowdStrike Falcon	⚠ Win/malicious_confidence_100% (W)
CTX	⚠ Exe.trojan.meterpreter	Cynet	⚠ Malicious (score: 100)
DeepInstinct	⚠ MALICIOUS	DrWeb	⚠ Trojan.Swrort.10
Elastic	⚠ Windows.Trojan.Metasploit	Emsisoft	⚠ Win32.Rozena.B (B)
eScan	⚠ Win32.Rozena.B	ESET-NOD32	⚠ Win32/Rozena.KC.gen Trojan
Fortinet	⚠ W32/Generic.AP.23ADC0!tr	GData	⚠ Win32.Rozena.B

Sottoponendo il file hash o md5 a virustotal che si basa sull'integrità dei file degli hash conosciuti invece vediamo che viene subito segnalato come file compromesso , ma ancora non abbiamo idea di dove avvenga precisamente la compromissione.

Per identificare qualcosa in piu' visto che non abbiamo visto il comportamento di notepad-classico.exe lo diamo in esecuzione a Floss.

Floss è un tool che decodifica automaticamente le stringhe offuscate e nascoste in memoria.

```
\.\
https
POST
POST
IoCompletion
tcp://192.168.50.100:9001
NPENCODINGDIALOG
MAINACC\tSLIPUPACC
&File
&Nuovo\tCTRL+N
&Apri...\tCTRL+F12
&Salva\tMAIUSC+F12
Sal&va con nome...
I&mposta pagina...
S&tampa...\tCTRL+MAIUSC+F12
&Esci
&Modifica
&Annulla\tCTRL+Z
&Taglia\tCTRL+X
&Copia\tCTRL+C
I&ncolla\tCTRL+V
E&limina\tCANC
Tr&ova...\tCTRL+T
T&rova successivo\tF3
&Sostituisci...\tCTRL+H
&Vai a...\tCTRL+G
Sele&ziona tutto\tCTRL+5 (Tn)
Ora/&Data\tF5
F&ormato
A capo a&utomatico
```

dopo aver guardato un po' la decodifica di floss possiamo notare come ci siano dentro al codice una serie di istruzioni normali e alcune "anormali" per un programma di testo , infatti vedendo questo screenshot troviamo degli indicatori di compromissione abbastanza evidenti:

tcp://192.168.50.100:9001

È una stringa di connessione di rete. Il malware tenta di stabilire una connessione TCP verso l'IP 192.168.50.100 sulla porta 9001.

Questo comportamento è tipico di una Reverse Shell (es. Netcat o simili) o di un beacon per un server di Command & Control (C2).

https e POST

Indicano che l'eseguibile è configurato per effettuare esfiltrazione di dati o ricevere comandi tramite richieste HTTP/HTTPS strutturate, utilizzando il metodo POST per inviare informazioni verso l'esterno.

IoCompletion

Fa riferimento alle porte di completamento di I/O (Input/Output Completion Ports) di Windows. Viene usata per gestire connessioni di rete asincrone ad alte prestazioni, confermando la presenza di un modulo di comunicazione di rete integrato nel finto Blocco note.

Con questi risultati siamo sicuri che il file è mascherato per fare da reverse shell verso l'indirizzo 192.168.50.100 alla porta 9001 .